DORA

Digital Operational Resilience Act — Governance, Risk, Controls, and Implementation Template

Joao Luiz D'Andrea

Table of contents

1 Executive Summary **3**

2 Overview **4**
2.1 Purpose . . . 4
2.2 Objectives . . . 4
2.3 Scope . . . 4
2.3.1 In scope . . . 4
2.3.2 Out of scope . . . 4
2.4 Intended Audience . . . 5

3 Regulatory Foundation **5**
3.1 Background . . . 5
3.2 Regulatory Objectives . . . 5
3.3 Core DORA Pillars . . . 5
3.4 Applicability and Entity Context . . . 6

4 Governance Model **6**
4.1 Governance Objectives . . . 6
4.2 Governance Structure . . . 6
4.2.1 Example governance bodies . . . 6
4.3 Three Lines Model . . . 7
4.3.1 First line . . . 7
4.3.2 Second line . . . 7
4.3.3 Third line . . . 7

5 Roles and Responsibilities **7**
5.1 Key Roles . . . 7
5.2 RACI Matrix . . . 8

6 Policy Framework **9**
6.1 Core Policies . . . 9
6.2 Standards and Procedures . . . 10

7 Core Processes **10**
7.1 ICT Risk Management . . . 10
7.2 ICT-Related Incident Management . . . 10
7.3 Incident Classification and Reporting . . . 11
7.4 Digital Operational Resilience Testing . . . 11
7.5 ICT Third-Party Risk Management . . . 11
7.6 Register of Information . . . 12
7.6.1 Minimum content . . . 12
7.7 Information Sharing Arrangements . . . 12

8 Control Framework **13**
8.1 Control Domains . . . 13
8.1.1 Example control domains . . . 13
8.2 Sample Control Catalogue . . . 13

9 Artefacts and Evidence **14**
9.1 Required Artefacts . . . 14
9.2 Evidence Model . . . 15

10 Architecture and Technology Implications **15**
10.1 Resilience by Design . . . 15
10.2 Technology Landscape View . . . 15
10.3 Dependency Mapping . . . 16

11 Risk Management **16**
11.1 DORA Risk Model . . . 16
11.2 Example Risk Categories . . . 16
11.3 Risk Register Template . . . 16

12 Metrics and Reporting **17**
12.1 Key Metrics . . . 17
12.2 Dashboard Structure . . . 17

13 Audit and Assurance **18**
13.1 Assurance Model . . . 18
13.2 Testing Themes . . . 18

14 Implementation Roadmap **18**
14.1 Maturity Phases . . . 18
14.1.1 Phase 1: Foundation . . . 18

14.1.2 Phase 2: Control Design 19
14.1.3 Phase 3: Integration 19
14.1.4 Phase 4: Optimisation 19
14.2 Roadmap Table 19

15 Cross-Framework Integration **19**
15.1 Relationship to Other Frameworks 19
15.2 Example Mapping Themes 20

16 Maturity Model **20**
16.1 Suggested Maturity Levels 20
16.1.1 Level 1: Initial 20
16.1.2 Level 2: Repeatable 20
16.1.3 Level 3: Defined 20
16.1.4 Level 4: Managed 21
16.1.5 Level 5: Optimised 21
16.2 Assessment Dimensions 21

17 Practical Templates **21**
17.1 Suggested Appendices 21

18 Customisation Notes **22**

19 References **22**

1 Executive Summary

The Digital Operational Resilience Act (DORA) establishes a harmonised European Union framework for managing digital operational resilience across the financial sector. It strengthens the ability of financial entities to withstand, respond to, and recover from ICT-related disruptions, cyber incidents, and third-party service failures.

This document provides a practical template for defining the organisation's DORA governance model, ICT risk management approach, control structure, implementation roadmap, and assurance model. It can be used to document how the organisation aligns resilience, cybersecurity, third-party risk, and regulatory compliance into a coherent operating model.

2 Overview

2.1 Purpose

This document provides a practical template for defining, implementing, operating, and assuring compliance with DORA across the enterprise.

2.2 Objectives

The main objectives of applying DORA are to:

- strengthen digital operational resilience across regulated financial services
- establish clear accountability for ICT risk and resilience
- improve prevention, detection, response, and recovery capabilities
- ensure consistent handling and reporting of ICT-related incidents
- strengthen oversight of ICT third-party dependencies and concentration risk
- support resilience testing and continuous improvement
- integrate operational resilience with enterprise governance, risk, compliance, and assurance

2.3 Scope

Describe the scope of DORA applicability in the organisation.

2.3.1 In scope

- regulated financial entities and relevant business functions
- ICT services supporting critical or important functions
- applications, infrastructure, cloud services, and networks
- cyber resilience, ICT operations, and service continuity arrangements
- ICT third-party service providers and contractual arrangements
- digital operational resilience testing activities
- incident management and regulatory reporting processes

2.3.2 Out of scope

Document justified exclusions, if any.

2.4 Intended Audience

- Board and executive leadership
- Chief Information Officer
- Chief Information Security Officer
- Chief Risk Officer
- Operational resilience teams
- Technology and operations teams
- Procurement and vendor management teams
- Legal and compliance teams
- Internal audit and assurance teams
- PMO / transformation teams

3 Regulatory Foundation

3.1 Background

DORA provides a unified regulatory framework for digital operational resilience in the financial sector. It addresses the management of ICT risk, resilience testing, ICT incident handling and reporting, ICT third-party risk, and supervisory oversight of critical ICT third-party providers.

3.2 Regulatory Objectives

Document how the organisation interprets the regulatory objectives of DORA:

- maintain resilience of ICT systems supporting business processes
- reduce the impact of ICT-related disruptions and cyber threats
- strengthen governance and accountability for ICT risk
- improve visibility and management of third-party dependencies
- increase consistency in resilience testing and incident reporting
- enhance financial sector-wide resilience

3.3 Core DORA Pillars

Describe how the organisation addresses the main DORA domains:

- ICT risk management
- ICT-related incident management, classification, and reporting
- digital operational resilience testing

- ICT third-party risk management
- information-sharing arrangements

3.4 Applicability and Entity Context

Document the specific applicability of DORA to the organisation, including:

- legal entity structure
- regulatory status
- business model
- group / subsidiary context
- jurisdictional footprint
- critical and important functions
- supervisory relationships

4 Governance Model

4.1 Governance Objectives

Define the governance objectives for DORA compliance:

- establish board-level oversight of digital operational resilience
- define accountability for ICT risk and resilience decisions
- align resilience priorities with enterprise risk appetite and business continuity objectives
- embed DORA requirements into operations, architecture, procurement, and change
- maintain evidence of compliance and control effectiveness
- support continuous improvement through testing, monitoring, assurance, and remediation

4.2 Governance Structure

Describe the governance bodies and their responsibilities.

4.2.1 Example governance bodies

- Board / Risk Committee
- Executive Operational Resilience Committee
- Technology and Security Steering Committee
- ICT Risk Committee
- Third-Party Risk Committee
- Architecture Review Board

- Incident Review Board
- Internal Audit

4.3 Three Lines Model

Describe responsibilities across the three lines.

4.3.1 First line

- ownership of business services, ICT operations, and controls
- implementation of resilience, security, and continuity controls
- incident handling and service restoration
- evidence production and remediation execution

4.3.2 Second line

- ICT risk oversight
- resilience policy and standards
- compliance monitoring
- independent challenge
- regulatory coordination

4.3.3 Third line

- internal audit
- independent assurance
- control effectiveness review

5 Roles and Responsibilities

5.1 Key Roles

Document the main DORA-related roles.

- Board
- CEO / Executive Management
- Chief Information Officer
- Chief Information Security Officer
- Chief Risk Officer

- Chief Operating Officer
- Operational Resilience Lead
- ICT Risk Manager
- Incident Response Lead
- Service Owner
- Infrastructure / Platform Owner
- Third-Party Risk Manager
- Procurement Lead
- Legal and Compliance Lead
- Internal Audit

5.2 RACI Matrix

Use the following model and adapt it.

Activity	Board	Exec	CIO	CISO	CRO	Ops Resilience	Service Owner	Third-Party Risk	Audit
Approve digital operational resilience strategy	A	R	C	C	C	C	I	I	I
Maintain ICT risk framework	I	A	R	R	C	C	C	I	I
Classify and report major ICT incidents	I	A	R	R	C	C	C	I	I

Activity	Board	Exec	CIO	CISO	CRO	Ops Resilience	Service Owner	Third-Party Risk	Audit
Maintain testing programme	I	A	C	C	C	R	C	I	I
Manage ICT third-party risk	I	A	C	C	C	C	C	R	I
Maintain register of information	I	A	C	C	C	C	I	R	I
Oversee remediation actions	I	A	R	R	C	C	R	C	I
Perform independent assurance	I	I	I	I	I	I	I	I	R/A

6 Policy Framework

6.1 Core Policies

List and describe the main DORA-related policies.

- Digital Operational Resilience Policy

- ICT Risk Management Policy
- Information Security Policy
- ICT Incident Management Policy
- Business Continuity and Disaster Recovery Policy
- Operational Resilience Testing Policy
- Third-Party Risk Management Policy
- Outsourcing / ICT Provider Management Policy
- Change and Release Management Policy
- Asset and Configuration Management Policy
- Logging and Monitoring Standard
- Crisis Management and Communications Policy

6.2 Standards and Procedures

Document the standards, procedures, playbooks, and operational guidance supporting compliance.

7 Core Processes

7.1 ICT Risk Management

Describe the process for managing ICT risk across the lifecycle:

- governance and accountability
- ICT asset identification
- risk assessment
- protection and prevention
- detection
- response
- recovery
- lessons learned
- continuous improvement

7.2 ICT-Related Incident Management

Describe the incident lifecycle:

- event detection
- triage
- classification

- escalation
- containment
- eradication
- recovery
- root cause analysis
- lessons learned

7.3 Incident Classification and Reporting

Document how the organisation handles:

- incident classification criteria
- major incident thresholds
- internal escalation
- competent authority notifications
- intermediate reporting
- final reporting
- post-incident review
- evidence retention

7.4 Digital Operational Resilience Testing

Describe the testing model for:

- annual testing planning
- scenario-based testing
- vulnerability assessments
- penetration testing
- business continuity testing
- disaster recovery exercises
- crisis management exercises
- threat-led penetration testing where applicable
- remediation tracking

7.5 ICT Third-Party Risk Management

Describe controls for:

- due diligence
- onboarding assessments
- contractual requirements

- criticality assessment
- concentration risk assessment
- ongoing monitoring
- exit planning
- substitution strategy
- assurance reviews

7.6 Register of Information

Document how the organisation maintains a complete and accurate register of information for contractual arrangements with ICT third-party service providers.

7.6.1 Minimum content

- supplier identity
- service description
- supported business entity
- supported function
- critical or important function flag
- location and jurisdiction
- subcontracting arrangements
- contract dates
- renewal terms
- exit clauses
- resilience and security obligations

7.7 Information Sharing Arrangements

Describe how the organisation governs participation in cyber threat intelligence or sectoral information-sharing arrangements, including:

- legal and compliance approval
- confidentiality controls
- participation criteria
- information handling requirements
- oversight and review

8 Control Framework

8.1 Control Domains

Organise the DORA control environment into domains.

8.1.1 Example control domains

- governance and oversight
- ICT risk management
- asset and dependency management
- protection and prevention
- monitoring and detection
- ICT incident response
- resilience and recovery
- testing and validation
- ICT third-party risk
- concentration risk management
- regulatory reporting
- evidence and assurance

8.2 Sample Control Catalogue

Control ID	Control Name	Objective	Control Owner	Frequency	Evidence
DORA-01	ICT risk framework approved	Ensure governance and accountability	CIO / CRO	Annual	Approved framework
DORA-02	Major incident process maintained	Ensure timely incident handling and escalation	CISO	Annual review	Incident procedure
DORA-03	Testing programme executed	Validate resilience capabilities	Resilience Lead	Annual / quarterly	Test reports

Control ID	Control Name	Objective	Control Owner	Frequency	Evidence
DORA-04	ICT third-party due diligence performed	Reduce supplier risk exposure	Third-Party Risk Manager	Onboarding / annual	Due diligence records
DORA-05	Register of information maintained	Ensure complete supplier transparency	Vendor Management Lead	Ongoing	Register of information
DORA-06	Recovery exercises completed	Validate restoration capability	Operations / Resilience Lead	Annual	Exercise evidence

9 Artefacts and Evidence

9.1 Required Artefacts

Document the key DORA artefacts.

- digital operational resilience strategy
- ICT risk management framework
- ICT asset inventory
- service dependency maps
- critical and important functions register
- ICT risk register
- incident management procedure
- major incident reporting procedure
- incident register
- testing policy and testing plan
- test scripts and exercise reports
- remediation tracker
- ICT third-party register
- register of information
- due diligence assessments
- contractual clause library
- exit plans
- business continuity plans
- disaster recovery plans
- crisis communication plans

- management information and dashboard packs
- audit reports

9.2 Evidence Model

For each artefact define:

- owner
- purpose
- location
- frequency of update
- retention period
- assurance mechanism

10 Architecture and Technology Implications

10.1 Resilience by Design

Describe how DORA requirements are embedded into:

- enterprise architecture
- solution design
- cloud adoption
- infrastructure engineering
- network design
- identity and access management
- observability and monitoring
- backup and recovery architecture
- high availability and failover design
- supplier integration patterns

10.2 Technology Landscape View

Document the resilience-relevant technology landscape:

- critical business services
- applications and platforms
- infrastructure and cloud services
- networks and communications
- data stores and backup services
- cyber tooling

- service desk and operations tooling
- third-party technology dependencies

10.3 Dependency Mapping

Include or reference:

- business service maps
- application dependency diagrams
- infrastructure dependency diagrams
- data flow diagrams
- third-party dependency maps
- concentration risk views
- recovery dependency maps

11 Risk Management

11.1 DORA Risk Model

Describe how ICT and resilience risks are identified, assessed, treated, monitored, and escalated.

11.2 Example Risk Categories

- weak board oversight of ICT risk
- incomplete ICT asset visibility
- inadequate resilience controls
- insufficient monitoring and detection
- delayed incident escalation
- poor recovery capability
- excessive third-party concentration
- weak contractual control over suppliers
- inaccurate register of information
- lack of evidence of testing and remediation

11.3 Risk Register Template

Risk ID	Risk Description	Cause	Impact	Likelihood	Inherent Risk	Control Strength	Residual Risk	Owner
DR-01	Example	Example	Example	Medium	High	Medium	Medium	Example

12 Metrics and Reporting

12.1 Key Metrics

Examples of DORA metrics:

- percentage of critical services with documented dependencies
- percentage of ICT assets covered by resilience controls
- number of major ICT incidents
- mean time to detect
- mean time to contain
- mean time to recover
- percentage of planned resilience tests completed
- percentage of severe findings remediated on time
- percentage of critical suppliers assessed
- concentration risk exposure by provider
- percentage completeness of register of information
- number of open audit or regulatory findings

12.2 Dashboard Structure

Suggested dashboard views:

- executive resilience dashboard
- ICT risk dashboard
- incident and recovery dashboard
- testing and remediation dashboard
- third-party and concentration risk dashboard
- audit and compliance dashboard

13 Audit and Assurance

13.1 Assurance Model

Document the assurance approach across:

- management self-assessment
- second-line compliance reviews
- control testing
- scenario and exercise validation
- internal audit
- supervisory review support

13.2 Testing Themes

- governance and accountability
- ICT risk framework effectiveness
- incident classification and escalation
- reporting timeliness and quality
- resilience testing coverage
- remediation effectiveness
- third-party governance
- register of information quality
- recovery readiness
- evidence completeness

14 Implementation Roadmap

14.1 Maturity Phases

14.1.1 Phase 1: Foundation

- establish governance and accountability
- define DORA policy framework
- identify critical and important functions
- establish asset and dependency baseline
- define incident classification and reporting model

14.1.2 Phase 2: Control Design

- strengthen ICT risk management controls
- implement resilience testing framework
- formalise third-party governance and register of information
- improve monitoring, response, and recovery controls

14.1.3 Phase 3: Integration

- integrate DORA with enterprise risk, architecture, and procurement
- improve dependency mapping and concentration risk management
- align service continuity, cyber resilience, and crisis management
- automate evidence collection and reporting workflows

14.1.4 Phase 4: Optimisation

- mature dashboards and management information
- strengthen scenario-based and threat-led exercises
- improve remediation governance
- enhance continuous monitoring and assurance

14.2 Roadmap Table

Initiative	Description	Owner	Priority	Timeline	Dependency	Status
Example	Example	Example	High	Q1-Q2	Example	Planned

15 Cross-Framework Integration

15.1 Relationship to Other Frameworks

Describe how DORA integrates with:

- NIS2
- ISO/IEC 27001
- GDPR
- AI Act
- NIST Cybersecurity Framework

- COBIT
- ITIL
- TOGAF
- enterprise risk management
- business continuity and operational resilience frameworks

15.2 Example Mapping Themes

DORA Theme	Related Framework	Integration Point
ICT risk management	ISO 27001 / NIST CSF	Cybersecurity and control framework
Incident reporting	NIS2 / GDPR	Regulatory notification and incident governance
Third-party risk	COBIT / ISO 27001	Supplier and outsourcing governance
Resilience testing	NIST CSF / BCM	Validation of resilience capabilities
Architecture resilience	TOGAF	Design authority and resilience by design

16 Maturity Model

16.1 Suggested Maturity Levels

16.1.1 Level 1: Initial

Resilience practices are reactive, fragmented, and poorly evidenced.

16.1.2 Level 2: Repeatable

Basic ICT risk, continuity, and incident processes exist but are inconsistently applied.

16.1.3 Level 3: Defined

Policies, roles, testing, and third-party controls are documented and implemented across key areas.

16.1.4 Level 4: Managed

Resilience capabilities are measured, risk-based, tested, and governed through regular reporting.

16.1.5 Level 5: Optimised

Digital operational resilience is embedded across governance, architecture, operations, and supply chain management with strong assurance and continuous improvement.

16.2 Assessment Dimensions

- governance
- ICT risk management
- incident handling and reporting
- resilience testing
- recovery capability
- third-party risk management
- concentration risk management
- evidence and reporting
- assurance
- improvement discipline

17 Practical Templates

17.1 Suggested Appendices

- Appendix A: ICT risk assessment template
- Appendix B: Major ICT incident classification template
- Appendix C: Incident reporting workflow
- Appendix D: Digital operational resilience testing plan
- Appendix E: Register of information template
- Appendix F: ICT third-party due diligence checklist
- Appendix G: DORA control catalogue
- Appendix H: DORA RACI matrix

18 Customisation Notes

This template should be tailored to reflect:

- legal entity structure
- supervisory context
- financial sector segment
- business service model
- technology estate
- cloud and outsourcing profile
- critical and important functions
- operational resilience maturity
- assurance expectations

19 References

Add authoritative references here, for example:

- Regulation (EU) 2022/2554
- DORA implementing and delegated acts
- ESA technical standards and guidance
- competent authority guidance
- internal ICT risk and resilience policies
- outsourcing and third-party risk standards
- enterprise risk framework